UNIVERSIDAD DEL VALLE
FACULTAD DE INGENIERÍA — ESCUELA DE SISTEMAS
MAESTRÍA EN DESARROLLO DE APLICACIONES INTELIGENTES
SEGURIDAD EN EL DESARROLLO DE APLICACIONES

Punto 1. Definición del caso de uso de IA

Módulo Tres: tareas de equipo púrpura para sistemas basados en IA

Miguel Ángel Rincón — 2502619-7729
Maria Paula Jimenez I — 2507713-7729
David Steven Duran Vallejo — 2508228-7729

> **Decisión de continuidad.** Se conserva el caso de uso trabajado en los dos módulos anteriores: evaluación automatizada de riesgo crediticio mediante el sistema de scoring de FinanCali S.A.S. No se cambia la organización ni la finalidad del sistema. Para hacer posible la evaluación práctica del Módulo Tres sin datos, infraestructura o modelos reales, se incorpora un prototipo sustituto local, pequeño y reproducible.

1.1. Justificación de la continuidad y de las actualizaciones

Mantener el caso de uso permite que el modelado de amenazas parta de los artefactos ya construidos. En el Módulo Uno se caracterizó a FinanCali como una fintech colombiana ficticia, de aproximadamente 50 empleados, cuya operación digital depende del flujo de originación de crédito. También se documentaron sus activos —datos personales y financieros, datos históricos, modelo, API, credenciales e infraestructura cloud—, sus dependencias externas y su madurez inicial. En el Módulo Dos se seleccionó NIST CSF 2.0 como marco principal y se identificaron resultados prioritarios en las funciones Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar. En particular, quedaron abiertas las amenazas especializadas contra el modelo, como el envenenamiento de datos, la evasión y la extracción. Esas brechas son el punto de entrada natural para el ejercicio adversarial del Módulo Tres.

Las actualizaciones introducidas no modifican el propósito del sistema. Precisan elementos que los talleres anteriores habían dejado como alternativas y que ahora deben ser verificables. El modelo se concreta como un clasificador tabular de *gradient boosting*; su probabilidad estimada se transforma en un score académico entre 0 y 100; el modelo se considera desarrollado internamente; y el entrenamiento continúa siendo por lotes, sin aprendizaje automático en producción. El prototipo utilizará el conjunto público *South German Credit* de UCI, bajo licencia CC BY 4.0, o una versión sintética derivada de su estructura [4]. Su empleo no supone que los datos representen a la población colombiana ni que el modelo sea apto para otorgar crédito real.

El prototipo será un sistema sustituto: preservará el tipo de modelo, la naturaleza tabular de las entradas, la salida probabilística, los umbrales de decisión y una interfaz de inferencia equivalente a la API descrita. No reproducirá el core financiero, la consulta real a centrales de riesgo, el desembolso, la cobranza ni la infraestructura cloud. Las conclusiones podrán extrapolarse a los mecanismos de ataque, integridad, versionamiento, detección y respuesta observados; no podrán extrapolarse al desempeño crediticio, la equidad poblacional ni el cumplimiento de un sistema productivo colombiano.

Tabla 1. Trazabilidad de las decisiones del caso

Elemento	Definición previa	Decisión para el Módulo Tres
Organización y proceso	FinanCali; originación digital de crédito de consumo.	Se mantienen sin cambios.
Tipo de modelo	Clasificación/regresión sobre datos tabulares.	Se concreta como clasificador *gradient boosting* que produce una probabilidad transformada a 0–100.

Elemento	Definición previa	Decisión para el Módulo Tres
Origen del modelo	Podía ser interno o adquirido.	Se asume desarrollo interno para poder observar entrenamiento, artefactos y controles. La adquisición permanece como escenario fuera de la prueba.
Datos	Datos declarados, historial interno y centrales de riesgo.	Se representan con datos públicos o sintéticos, sin titulares reales de FinanCali.
Despliegue	Microservicio cloud mediante API REST interna.	Se simula localmente con una función o endpoint REST y registros de solicitudes.
Volumen	Cientos de solicitudes diarias.	Se simula mediante lotes de solicitudes. El volumen académico no pretende reproducir capacidad productiva.
Marco de seguridad	NIST CSF 2.0; CIS Controls como apoyo técnico.	Se mantiene NIST CSF 2.0 y se utilizarán específicamente Identificar, Proteger y Detectar, como exige el Módulo Tres.

1.2. Plantilla diligenciada del caso de uso

1. Identificación general

Campo	Documentación del caso
Nombre	Evaluación automatizada de riesgo crediticio — Sistema de scoring de FinanCali S.A.S.
Objetivo de negocio	Reducir el tiempo de respuesta de las solicitudes y mejorar la consistencia de la originación, sin depender exclusivamente del juicio manual.
Objetivo de la IA	Estimar, a partir de variables tabulares, la probabilidad asociada al comportamiento crediticio y convertirla en un score de 0 a 100 que alimente una recomendación de aprobar, revisar o rechazar.
Proceso asociado	Originación de crédito digital, desde la captura y validación de la solicitud hasta la recomendación entregada al motor de decisión o al analista.
Objeto del análisis en este módulo	El pipeline de entrenamiento, el artefacto del modelo, la interfaz de inferencia y los registros necesarios para identificar, proteger y detectar acciones adversariales.

2. Dimensión técnica

Campo	Documentación del caso
Modelo o técnica	Clasificación binaria sobre datos tabulares mediante *GradientBoostingClassifier*. La probabilidad de la clase favorable se escala a un score de 0 a 100. Esta implementación concreta la formulación general de los talleres anteriores.
Naturaleza del aprendizaje	Aprendizaje supervisado y entrenamiento por lotes. No existe reentrenamiento automático en producción. Un nuevo modelo debe pasar por preparación, entrenamiento, evaluación, versionamiento y aprobación.
Autonomía	Semiautónoma. Para el prototipo se usarán umbrales académicos explícitos: score de 0 a 39, rechazo; 40 a 69, revisión manual; y 70 a 100, aprobación. No representan una política financiera real y podrán ajustarse antes de la prueba, dejando registro del cambio.
Despliegue	El caso conceptual conserva un microservicio cloud expuesto internamente por API REST. El sustituto se ejecutará localmente y podrá ofrecer un endpoint `POST /score` o una función equivalente. La interfaz web, si se construye, será únicamente una capa de demostración.
Integraciones	En el caso realista: aplicación web/móvil, core de crédito, central de riesgo, verificación de identidad y gestión documental. En el sustituto: archivos locales o respuestas simuladas; no se invocarán servicios financieros reales.
Componentes observables	Dataset versionado, script de preparación, modelo serializado, configuración, métricas, endpoint de inferencia y registros. Estos artefactos permitirán obtener evidencia de la prueba.

```
FLUJO DE ENTRENAMIENTO
Datos públicos/sintéticos → preparación → entrenamiento → evaluación
→ validación de seguridad → versión aprobada → artefacto desplegable

FLUJO DE INFERENCIA
Formulario simulado → validación → endpoint /score → modelo
→ score 0–100 → aprobar / revisar / rechazar → registro

LÍMITE DEL EJERCICIO
No hay central de riesgo, datos personales reales, core bancario,
desembolso, nube productiva ni decisión financiera efectiva.
```

3. Dimensión de datos

Campo	Documentación del caso
Fuentes conceptuales	Información declarada por el solicitante, historial interno de FinanCali y reportes de centrales de riesgo, tal como se definió en el Módulo Uno.
Fuente del prototipo	*South German Credit* de UCI —20 variables predictoras y una etiqueta binaria— o una versión sintética con estructura equivalente [4]. Se conservará la atribución exigida por CC BY 4.0. No se usará la versión Statlog con errores de codificación reportados.
Naturaleza y sensibilidad	El caso conceptual trata datos personales, financieros y crediticios identificables. El prototipo empleará datos públicos históricos o sintéticos sin relación con clientes de FinanCali. Que el archivo sea público no convierte sus variables en apropiadas para una decisión real.
Variables	Se priorizarán variables equivalentes a monto, duración, situación de cuenta, historial, ahorro, empleo y obligaciones. Variables como sexo, edad o condición de extranjero no se usarán como predictores del prototipo base; podrán conservarse únicamente, si resulta metodológicamente necesario, para análisis separado y documentado.
Actualización	Las entradas de una solicitud se capturan al momento de la inferencia. El dataset de entrenamiento es una versión congelada; cada modificación debe generar una nueva versión identificable.
Retención y trazabilidad	Se conservarán versión del dataset, hash, semilla, configuración, versión del modelo, métricas y resultados de prueba. Los registros no contendrán identidades reales. La conservación busca reproducibilidad académica, no simula el término legal de un expediente crediticio.
Separación de variables	Antes de la evaluación adversarial se marcarán las variables que un solicitante podría declarar, las que provendrían de una fuente externa confiable y las derivadas por FinanCali. Esta clasificación evita considerar factibles perturbaciones que un adversario no podría producir.

4. Dimensión operativa

Campo	Documentación del caso
Volumen	El caso conserva el orden de cientos de solicitudes diarias. El prototipo ejecutará lotes pequeños y repetibles; el volumen simulado se documentará en cada prueba.
Supervisión humana	Un analista revisa la franja intermedia. En el prototipo no se tomarán decisiones sobre personas: la “revisión manual” será un estado de salida y podrá acompañarse de una razón simulada.
Falla o indisponibilidad	El caso mantiene el flujo manual de respaldo. Durante la simulación, una falla del modelo o de una validación de seguridad debe impedir el despliegue o enviar la solicitud al estado de revisión, sin aprobarla automáticamente.
Operación segura de la prueba	Las acciones ofensivas se ejecutarán solo en el entorno local, sobre artefactos propios y datos públicos o sintéticos. Se fijará una semilla y se conservarán las entradas, salidas y configuraciones.

5. Usuarios y poblaciones afectadas

Campo	Documentación del caso
Usuarios directos	En el caso: analistas de crédito y motor de decisión. En el prototipo: integrantes del grupo que ejecuten y observen la prueba.
Población afectada	Conceptualmente, personas naturales solicitantes de crédito de consumo en Colombia. En el ejercicio no hay titulares ni decisiones reales; cada “solicitante” es un registro público desidentificado o sintético.
Canal de interacción	Conceptualmente, aplicación web y móvil de FinanCali. En el sustituto, un formulario web local o casos de prueba enviados directamente a la función/API.
Impacto relevante	En un sistema real, una alteración podría producir aprobación o rechazo incorrectos, pérdida económica, discriminación o afectación del habeas data. En el prototipo, el impacto se mide como cambio de predicción, desempeño o comportamiento del pipeline.

6. Contexto de despliegue

Campo	Documentación del caso
Alcance territorial	FinanCali opera exclusivamente en Colombia. El dataset extranjero se utiliza solo como material de prueba y no modifica ese alcance.
Sector	Financiero-tecnológico, crédito digital con recursos propios en el escenario base definido en el Módulo Uno.
Criticidad	Alta para el caso conceptual porque el scoring forma parte del flujo central de originación. Académica y controlada para el prototipo, que no tiene consecuencias externas.
Marco normativo de referencia	Leyes 1581 de 2012 y 1266 de 2008, modificación de la Ley 2157 de 2021 y Circular Externa 002 de 2024 de la SIC, según el panorama del Módulo Uno. Su consideración orienta el diseño; no convierte el prototipo en un sistema conforme ni certificado.

7. Madurez de adopción de IA

Campo	Documentación del caso
Madurez actual	Inicial: modelo conceptualmente en producción, monitoreo operativo básico, inventario parcial y ausencia de un programa formal de gobernanza de IA.
Gobernanza	No existe rol o comité formal; las decisiones recaen en el equipo técnico. Para la simulación se asignarán responsables de datos, modelo, actividad ofensiva y actividad defensiva.
Monitoreo	El diagnóstico previo solo contemplaba disponibilidad. El prototipo agregará una línea base de integridad, distribución y desempeño para que los puntos siguientes puedan evaluar detección. Esto constituye instrumentación del ejercicio, no evidencia de que FinanCali ya posea esa capacidad.
Marco adoptado	NIST CSF 2.0. El Módulo Tres concentrará las acciones en `ID` Identificar, `PR` Proteger y `DE` Detectar.

1.3. Alcance preparado para los puntos siguientes

La definición anterior deja disponibles cuatro superficies para el análisis ATLAS: datos de entrenamiento, pipeline de preparación, artefacto del modelo e interfaz de inferencia. En el Punto 2 no se asumirá que toda técnica es factible. Para cada candidata se comprobará si el componente existe, qué acceso necesita el adversario y qué exposición presenta. La presencia de un riesgo de equidad o de deriva tampoco se presentará automáticamente como ataque: solo será una amenaza adversarial cuando exista una acción intencional y una técnica ATLAS pertinente.

La prueba práctica del Punto 3 deberá usar una versión congelada de este caso. Antes de ejecutarla se fijarán el dataset, el hash, la semilla, el modelo, los umbrales, el objetivo ofensivo, el comportamiento esperado y el criterio de aprobación. La interfaz web podrá apoyar la demostración, pero la evidencia principal serán los registros, configuraciones, métricas y resultados reproducibles. De esta manera, el prototipo no intenta sustituir una plataforma financiera; materializa únicamente los componentes indispensables para evaluar una amenaza y su defensa.

1.4. Conclusión del Punto 1

El caso de uso no cambia respecto de los módulos anteriores: continúa siendo el scoring crediticio semiautónomo de FinanCali. La actualización consiste en hacerlo comprobable mediante un sustituto local basado en clasificación tabular y datos públicos o sintéticos, sin titulares reales ni decisiones de crédito efectivas. Se preservan el propósito, la lógica, la superficie técnica y las brechas previamente documentadas, al tiempo que se establecen artefactos observables para modelar amenazas, ejecutar una prueba de equipo púrpura y relacionar sus resultados con NIST CSF 2.0. La equivalencia es suficiente para estudiar mecanismos de seguridad; no autoriza conclusiones sobre desempeño, equidad o cumplimiento de un sistema productivo.

Referencias

1. FinanCali S.A.S. *Taller 1 — Propuesta del proyecto*. Artefacto académico del Módulo Uno.
2. FinanCali S.A.S. *Taller 2 — Marcos de Trabajo de Ciberseguridad*. Artefacto académico del Módulo Dos.
3. Universidad del Valle. *Módulo Tres: Tareas de equipo púrpura para sistemas basados en IA*. Seguridad en el Desarrollo de Aplicaciones, 2026-II.
4. Grömping, U. *South German Credit*. UCI Machine Learning Repository. DOI: 10.24432/C5X89F. Licencia CC BY 4.0. https://archive.ics.uci.edu/dataset/522/south+german+credit
5. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29, 2024.